

Equipo 2. Entregable 6

TAREA 6 – Seguridad básica y respuesta a incidentes (phishing / accesos / malware)

TAREA 6 – Seguridad básica y respuesta a incidentes (phishing / accesos / malware)

Objetivo general

En este documento se demostrará que se tienen los conocimientos para detectar, contener y documentar un incidente básico de seguridad de primer nivel.

Parte A. Elección de un escenario

Para el incidente documentado en esta tarea, se eligió de escenario el siguiente caso de phishing:

El usuario reportó la recepción de un correo electrónico sospechoso solicitando la verificación urgente de credenciales para evitar la suspensión inmediata de su cuenta corporativa.

Remitente Sospechoso: *soporte-soporteit@mail-fix-security.com (Simulación de identidad interna).*

Vector de Ataque: *Ingeniería social con coerción (plazo límite de 24 horas).*

URL Maliciosa Registrada: *http://185[.]220[.]101[.]5/login-verify (IP pública externa sin HTTPS).*

Parte B. Señales de riesgo detectadas

En esta parte se mencionan las señales que demuestran que se puede tratar de un caso de phishing y, por lo tanto, el equipo del usuario está en riesgo. Estas señales fueron:

- **Inconsistencia en el remitente:** La dirección visible indica Soporte TI, pero el dominio real tras el @ proviene de un servidor externo no corporativo (soporte-soporteit@mail-fix-security.com).

- **Urgencia y coerción en el mensaje:** Exigencia de verificar credenciales en menos de 24 horas bajo amenaza de suspensión de cuenta.
- **Enlace manipulado / URL sospechosa:** El hipervínculo apunta a una IP pública externa sin certificado SSL válido (<http://185.220.101.5/login>) en lugar del portal institucional.

PARTE C. RESPUESTA OPERATIVA L1

1.- Acción de Contención Inmediata

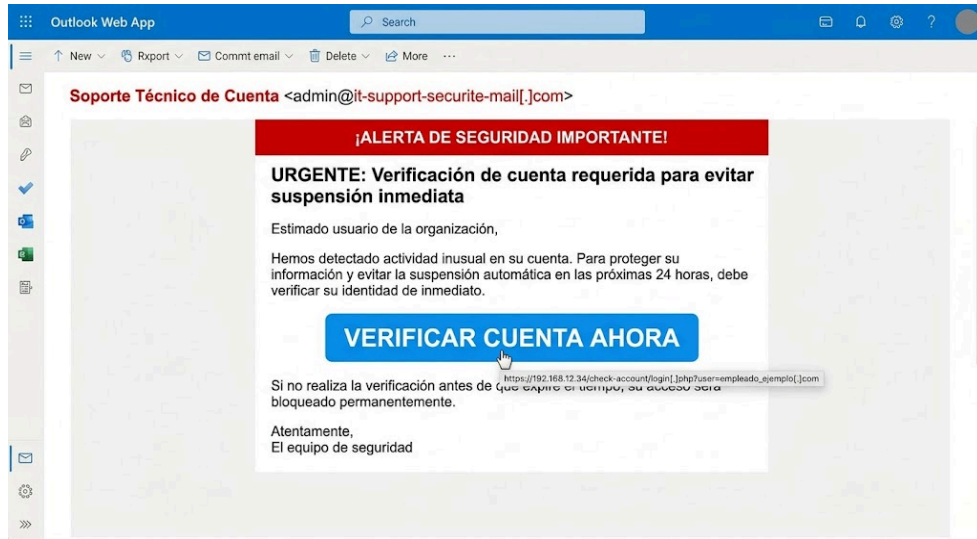
Instruir inmediatamente al usuario a no hacer clic ni interactuar con el mensaje.

- **Si ingresó datos:** Forzar reseteo inmediato de contraseña desde el panel de identidad y cerrar todas las sesiones activas.
- **Si descargó un adjunto:** Aislar el equipo de la red (desconectar cable Ethernet y apagar Wi-Fi).

2.- Recolección de Información de IOCs

- Obtener las cabeceras completas (headers) del correo y tomar captura de pantalla del cuerpo del mensaje.
- Registrar la fecha/hora exacta de recepción y aislar la URL maliciosa desarmada en texto plano.

Tipo de IOC	Valor Registrado
Remitente Falso	soporte-soporteit@mail-fix-security.com
URL de Phishing	http://185.[.]220[.]101[.]5/login-verify



3.- Escalamiento Jerárquico

Transferir el ticket a Seguridad / SOC (Tier 2) con los IOCs adjuntos para solicitar el bloqueo de dominio/IP en el Gateway de correo y el purgado masivo de buzones.

4.- Registro y Documentación

Ticket

Especialista que atendió

Cinthia Belmont

1. Información del Usuario

Nombre

Carlos Mendoza

Correo Electrónico

cmendoza@gmail.com

Teléfono / Extensión

223 786 8672

Departamento / Área

Finanzas

2. Información del Problema

Categoría

Seguridad

Prioridad

Crítica

Descripción del Problema

Ticket # 0892 incidente.

Señales de riesgo detectados:

- Inconsistencia en el Remitente: La dirección que se observa e indica Soporte TI, el dominio real tras el @ proviene de un servidor externo no corporativo (soporte-soporteit@mail-fix-security.com).
- Urgencia y coerción en el mensaje: Exigencia de verificar credenciales en menos de 24 horas bajo amenaza de suspensión de cuenta.
- URL sospechosa: El hipervínculo apunta a una IP pública externa sin certificado SSL válido (http://185.220.101.5/login) en lugar del portal institucional.

3. Diagnóstico Inicial

Posibles Causas

- Ataque dirigido de ingeniería social (Phishing de credenciales) con suplantación de identidad del área corporativa de Soporte TI.

- Filtración o exposición previa del correo del usuario Carlos Mendoza desde su correo "cmendoza@gmail.com" en bases de datos públicas o brechas de seguridad externas.

- Infiltración del correo malicioso mediante evasión de filtros anti-spam/seguridad por el uso de un dominio nuevo.

- Intento de robo de identidad para obtener acceso no autorizado a los sistemas internos del departamento de Finanzas.

4. Resolución del Ticket

Acciones Realizadas

1. Notificación inmediata al usuario para omitir interacción con el correo.

2. Restablecimiento forzado de contraseña y revocación de sesiones activas.

3. Extracción de cabeceras y escalamiento a SOC Nivel 2 para bloqueo de IP/dominio remitente.

5. Cierre del Ticket

Satisfacción del Usuario

Muy Satisfecho

Enviar

Parte D. Recomendación al usuario

Un consejo hacia los usuarios para poder prevenir este tipo de amenazas hacia la seguridad de sus equipos es:

"Recuerde que el área de Soporte TI nunca le solicitará su contraseña ni la verificación de su cuenta mediante enlaces enviados por correo electrónico. Si vuelve a recibir un mensaje con tono de urgencia o de un remitente extraño, evite hacer clic en sus enlaces y repórtelo de inmediato mediante el botón 'Reportar Phishing' o contactando a la Mesa de Ayuda."